

Step 02 — Auth (manual test guide)

Goal: Confirm register/login, password hashing, httpOnly JWT cookie session, and `/api/auth/me` .

Maps to: Phase 1 — Foundation

Do not start Step 03 until every required item passes.

Artifacts:

- Markdown: `docs/manual-test-guides/step-02-auth.md`
- PDF: `docs/manual-test-guides/step-02-auth.pdf`

Prerequisites

- ☐ Step 01 scaffold already passing
- ☐ PostgreSQL running; `fms_dev` exists
- ☐ `server/.env` includes `DATABASE_URL` and `JWT_SECRET` (min 32 chars; see `.env.example`)
- ☐ Migration applied: `npx prisma migrate dev` (includes `step02_auth`)

Setup commands

Server:

```
cd finance-management/server
npm install
npx prisma generate
npx prisma migrate dev
npm run dev
```

Client (new terminal):

```
cd finance-management/client
npm install
npm run dev
```

Checklist

A. Register

#	Test	Expected	Pass?
A1	POST <code>/api/auth/register</code> with valid email, password (≥ 8), optional name	HTTP 201, <code>ok: true</code> , user without password; <code>Set-Cookie: fms_token=...</code> (httpOnly)	[]
A2	Open http://localhost:5173/register and create an account	Redirects to home; shows email/role	[]

A3	Register again with the same email	HTTP 409 / UI error "Email is already registered"	[]
A4	Register with password shorter than 8 chars	HTTP 400 validation error	[]

Example (PowerShell-friendly curl):

```
curl -i -X POST http://localhost:4000/api/auth/register \
  -H "Content-Type: application/json" \
  -d '{"email":"demo@example.com","password":"password123","name":"Demo"}'
```

B. Login / logout / me

#	Test	Expected	Pass?
B1	POST /api/auth/login with correct credentials	HTTP 200, user payload, cookie set	[]
B2	GET /api/auth/me with cookie (browser session or -b cookie jar)	HTTP 200, same user	[]
B3	GET /api/auth/me without cookie	HTTP 401	[]
B4	Login with wrong password	HTTP 401 "Invalid email or password"	[]
B5	POST /api/auth/logout then GET /api/auth/me	Cookie cleared; me returns 401	[]
B6	UI: sign in at /login, then Sign out on home	Session cleared; redirected to login	[]

C. Security smoke

#	Test	Expected	Pass?
C1	Inspect network response for register/login	No password / passwordHash in JSON	[]
C2	Check cookie flags in DevTools	HttpOnly; SameSite=Lax	[]
C3	Confirm DB row	users table has bcrypt hash (starts with \$2), not plain password	[]

D. Coding rules smoke

#	Test	Expected	Pass?
D1	Controllers call services	authController → authService (no Prisma in routes)	[]
D2	Zod validates body	Invalid payloads fail in validator / error handler	[]
D3	requireAuth middleware	Protects /api/auth/me	[]

Pass criteria for Step 02

- ☐ A1–A4 pass
- ☐ B1–B6 pass
- ☐ C1–C3 pass
- ☐ D1–D3 pass

When all required items pass: mark Notion **Step 02: Auth...** and **Implement authentication...** Done, then start **Step 03 — Tenants + Super Admin.**

Notes / failures

Item	What failed	Fix applied

Optional PDF

Printable copy of this guide:

`docs/manual-test-guides/step-02-auth.pdf`